

【 별표 4 】

국가데이터처 정보자산 보안관리 지침

1. (목적) 국가데이터처 내부 정보자산이 중요도에 따라 적절한 수준으로 보호되도록 분류하고 자산별 보안 등급을 명확히 함으로써 국가데이터처의 정보자산을 효과적으로 보호함을 목적으로 한다.
2. (정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.
 - 가. "정보자산"이란 국가데이터처가 소유하고 있는 정보 및 정보시스템을 통칭하며, 정보시스템에는 국가데이터처가 관리하는 모든 하드웨어, 소프트웨어, 네트워크가 포함된다.
 - 나. "자산분류"란 정보시스템에서 적절한 보호 통제가 취해질 수 있도록 자산을 체계적으로 구분하는 것을 의미한다.
 - 다. "기밀성(Confidentiality : C)"이란 비인가자가 임의로 정보를 사용하거나 비인가자에게 임의로 정보가 노출되지 못하도록 하는 특성이다. 정보자산 또는 데이터가 전송, 백업, 보관 중에 허가받지 않은 사람에게 노출되지 않아야 함을 의미한다.
 - 라. "무결성(Integrity : I)"이란 비인가된 방법을 통해 정보를 변경 또는 파괴하지 못하도록 하는 특성이다. 정보가 전송되고 저장되는 과정에서 완전성과 정확성을 유지하는 것을 의미한다.
 - 마. "가용성(Availability : A)"이란 권한을 가진 개체의 요구에 따라 해당 정보자산에 지속적으로 접근하고 사용이 가능하도록 하는 특성이다.
3. (적용범위) 이 지침은 국가데이터처 업무와 관련된 전자정보, 시스템, 네트워크, 보안시스템 등을 포괄하는 정보자산에 적용한다.

4. 정보자산 책임자

- 가. 정보자산 책임자는 시스템, 네트워크, 보안시스템 등 정보자산을 총괄적으로 도입·관리·감독하며, 정보보안담당관이 국가데이터처 정보자산 책임자가 된다.
- 나. 정보자산 책임자는 개별 정보자산을 식별하고 적절히 통제하기 위하여 정보시스템(서버, 어플리케이션) 분야는 정보자원기획 담당사무관(서기관)을, 네트워크·보안시스템 분야는 정보보안 담당사무관(서기관)을 정보자산 관리자로 지정한다.

5. 정보자산 관리자

- 가. 정보자산 관리자는 정보자산 책임자가 제4호 나목에서 지정한 자로 정보자산을 실질적으로 관리한다.
- 나. 정보자산 관리자는 본 지침에서 제시하고 있는 분류 체계에 따라 정보자산을 식별하고 각 정보자산의 중요성에 대한 평가업무를 수행하는 등의 실무 업무를 담당한다.

6. 정보자산 사용자

- 가. 정보자산 사용자는 정보자산 관리자의 관리 하에 정보자산을 실질적으로 업무에 사용하는 자를 말한다.
- 나. 정보자산 사용자는 정보자산 책임자의 허가 아래 정보자산을 사용해야 하고, 비인가 등 통제되지 아니한 정보자산을 포함하여 업무와 무관한 어떠한 정보자산에도 접근을 시도해서는 아니 된다.
- 다. 정보자산 사용 시 정보자산의 유출 및 파손 사고 등이 발생하였을 경우 이에 대한 최종 책임은 정보자산 사용자가 진다.

7. 정보자산 관리 책임

- 가. 정보자산에 대한 관리 책임은 1차적으로 정보자산 사용자에게 있고, 2차적으로

정보자산 관리자에게 있다.

나. 가목의 규정에도 불구하고 정보자산 관리자의 중대한 실수나 고의로 인한 사고에 대해서는 정보자산 관리자가 1차 책임을 진다. 이 경우 중대한 실수란 정보보안 사고를 야기하게 된 직접적인 원인을 제공한 경우를 의미한다.

8. 정보자산의 분류

가. 정보자산은 유형에 따라 다음 각 세부호와 같이 분류하여 관리한다.

- 1). 전자정보 : 전자적인 형태로 저장되는 자산으로 데이터베이스나 데이터 파일 내의 업무 관련정보, 인사정보, 통계자료, 전자형태의 각종 문서, 매뉴얼 등 서버 및 데이터베이스 내의 각종 자료
- 2). 시스템 자산 : 국가데이터처에서 제공하는 IT 관련 서비스 및 관련 업무를 위해 사용되는 서버 등의 하드웨어와 관련된 OS로 유닉스 서버, 윈도우 서버 등을 포함
- 3). 네트워크 자산 : 네트워크와 관련된 장비로 라우터, 스위치 등을 포함
- 4). 보안시스템 : 침입차단시스템과 침입탐지시스템 그리고 취약점 분석도구와 같은 정보자산을 보호하기 위한 각종 소프트웨어, 하드웨어 등을 포함

나. 정보에 보호등급이 부여된 경우, 이를 포함하는 정보시스템(서버, 애플리케이션, 네트워크 등)은 기본적으로 해당 정보의 보호등급을 그대로 이어받는 것을 원칙으로 한다.

9. (정보자산 목록 작성) 정보자산을 도입하거나 새로운 정보자산이 생성될 때에는 다음 각 목의 절차에 따라 정보자산 목록을 작성하여야 한다.

가. 정보자산 책임자는 정보자산을 도입하거나 새로운 자산이 생성될 때 정보자산 목록 작성

나. 정보자산 책임자는 해당 정보자산 관리자에게 정보자산 목록의 작성을 요청

다. 해당 정보자산 관리자는 본 지침에서 제시한 정보자산 목록 작성방법에 따라

[서식 제31호]에 정보자산 목록 작성

10. (정보의 보호등급) 정보의 보호등급은 다음 각 목과 같다.

가. ‘가’급 정보 : 국가데이터처 내·외부에 부당하게 공개되거나 누설될 경우, 국가데이터처의 조직 활동에 중대한 영향을 미칠 가능성이 있는 정보로서 ‘업무상 접근 권한을 가진 한정된 직원’에게만 제공되도록 관리되어야 하는 다음 각 목의 정보

- 1). 비밀정보 : 내용이 누설되는 경우 국가안전보장에 유해로운 결과를 초래할 우려가 있는 국가 기밀로서 처장 및 비밀취급인가자만이 취급 가능한 정보
- 2). 핵심정보 : 업무상 중요하게 취급되는 정보
- 3). 개인정보 : 개인을 식별할 수 있는 정보

나. ‘나’급 정보 : 업무상 국가데이터처 내부에서 취급되어야 하는 정보로서, 외부 유출 시 상당한 문제를 야기하거나 손실을 가져와 취급 및 배포를 통제해야 하는 다음 각 목의 정보

- 1). 업무정보 : 전자결재관련정보, 부서별 업무정보 등 업무상 중요하게 취급되어야 하는 정보로 별도 관리책임자 혹은 업무담당자만이 취급 가능한 정보
- 2). 처내 공개정보 : 처 내 전 직원이 사용 가능한 게시판, 공용문서 등을 포함하며 처 외 유출을 억제하여야 하는 정보

다. ‘다’급 정보 : 상기 ‘가’급, ‘나’급 정보 이외의 정보로 국가데이터처 외부에 공표되거나 공개할 수 있는 홈페이지 정보, 공개 정보 등

11. 정보자산의 중요성 평가

가. 정보자산에 대한 중요성 평가는 다음 각 세부호와 같이 실시한다.

- 1). [별표 10] 정보자산 중요성 평가기준에 따라 평가
- 2). 정보자산 관리자는 기본적으로 연 1회 정보자산 목록에 신규 등록된 정보자산에 대해 [별표 10의2] 정보자산 중요성 평가 등급 기준에 따라

정보자산의 중요성 평가

나. 정보자산 중요성 평가 기준과 방법은 다음 각 세부호와 같다.

- 1). 정보자산의 중요성 평가는 정보자산 관리자가 [별표 10]에 따라 정보의 보호등급을 고려하여 기밀성, 무결성, 가용성에 대하여 상(3점), 중(2점), 하(1점)의 3점 척도를 이용하여 평가
- 2). 기밀성, 무결성, 가용성 각각에 대한 평가등급은 [별표 10의2]을 이용하여 도출
 - 정보자산 중요성 지수 = (기밀성 요구정도 + 무결성 요구정도 + 가용성 요구정도)

12. (정보자산 관리) 정보자산이 적절한 수준의 보호를 받을 있도록 하기 위하여는 다음 각 목의 사항을 수행하여야 한다.

가. 제11호 나목의 정보자산 중요성 평가 기준과 방법에 명시된 바와 같이 정보자산 관리자가 [별표 10]에 따라 정보자산의 중요성을 [서식 제31호]에 기록

나. [별표 10의2]에 따라 정보자산 등급을 국가정보원의 ‘국가정보보안 기본지침’의 전자정보 보호등급 분류에서 구분한 것과 같이 ‘가’, ‘나’, ‘다’ 등급으로 각각 분류

다. 정보자산 관리자는 정기적인 중요성 평가 이외에 자산의 이동, 변경 또는 폐기 등이 발생하는 경우 수시로 정보자산 평가를 실시하여 정보자산 목록에 반영

13. 정보자산의 이동 통제

가. 정보자산은 원칙적으로 해당 정보자산 책임자의 허가 없이 옮겨져서는 아니 된다.

나. 정보자산은 이동 시 기밀성, 무결성, 가용성이 최대한 유지되도록 적절한 방법에 의해 통제되어야 하며, 정보자산의 이동은 반드시 해당 정보자산 책임자의 승인을 받아야 한다.

다. 정보자산의 책임자 및 관리자는 해당 정보자산의 이동 등 변경사항에 대해

항시 점검하고 파악하고 있어야 한다.

라. 비밀 자료 및 이에 준하는 정보를 외부 또는 타 과에 정보통신수단을 통해 송수신하는 등의 경우는 「국가정보보안 기본지침」의 비밀의 전자적 처리에서 명시한 바에 따른다.

14. (정보자산의 인계인수) 정보자산 책임자 및 관리자가 교체되는 경우에는 정보자산을 인계인수하고 인계인수서를 작성하여야 한다.